

IT PROFESSIONAL PORTFOLIO

Cloud Engineering and Security Projects

PROJECT 36

Deploy and Clean Up a Controlled Public SSH Exposure for GuardDuty Detection

Amazon GuardDuty | Security Hub | EventBridge | SNS | EC2 | CloudFormation

AUTHOR	Michael Salazar
ENVIRONMENT	Personal AWS Lab
VERSION	v1.0.3
RELEASE DATE	July 27, 2026
STATUS	Closed - Detection Validated and Stack Deleted

Executive Summary

Created the **Exposed** CloudFormation stack to intentionally deploy a public EC2 instance named **HackMePlease** with **TCP 22** open to the Internet. The instance was designed as a controlled detection target with no IAM role or instance profile. After the exposure generated a GuardDuty finding that was imported into Security Hub and delivered through the SecurityHubAlerts email path, the Exposed CloudFormation stack was deleted. This patch release closes the lab lifecycle by documenting exposure, detection validation, alert delivery, and cleanup.

LIFECYCLE UPDATE

This lab intentionally created Internet exposure to test detective controls. The exposed stack has now been deleted, so the project status changes from detection validated to closed / remediated.

Business Problem

Detective controls are only useful if they fire under realistic conditions and route findings to the right destination. This lab intentionally exposed SSH on a controlled EC2 target so GuardDuty, Security Hub, EventBridge, and SNS could be validated end-to-end. The cleanup step proves the operator can remove the intentionally risky resource after detection evidence is captured.

Objectives

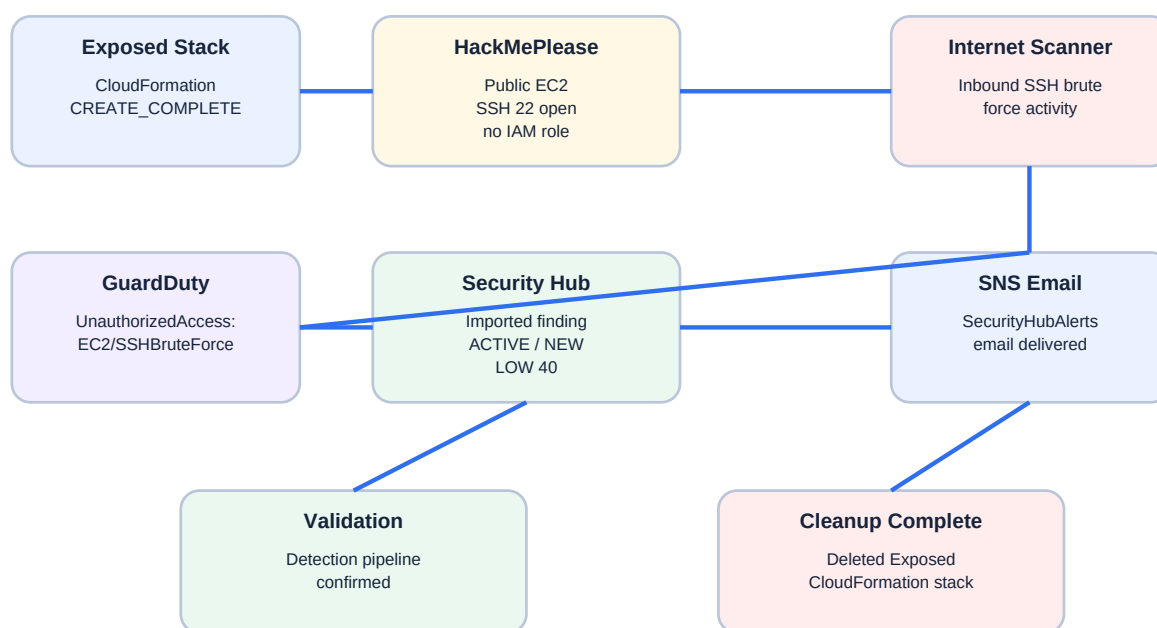
- Create the Exposed CloudFormation stack in TestAccount1.
- Deploy a public EC2 instance named HackMePlease as a controlled detection target.
- Open inbound SSH on TCP 22 to 0.0.0.0/0 according to the lab design.
- Avoid attaching an EC2 IAM role or instance profile to reduce AWS API blast radius.
- Receive a GuardDuty SSH brute-force finding imported into Security Hub.
- Validate the SecurityHubAlerts email notification path created in Project 24.
- Delete the Exposed CloudFormation stack after detection validation.
- Document that cleanup was completed based on the user-provided implementation update; no separate deletion screenshot was provided.

Environment

Cloud Provider	Amazon Web Services (AWS)
Primary Services	Amazon EC2, AWS CloudFormation, Amazon GuardDuty, AWS Security Hub, Amazon EventBridge, Amazon SNS
Account Context	TestAccount1 / AdministratorAccess
Stack Name	Exposed

Instance Name	HackMePlease
Instance Type	t2.micro in evidence
Region	us-west-2 / Oregon
Exposure	Inbound TCP 22 from 0.0.0.0/0; outbound all traffic to 0.0.0.0/0
IAM Role	None / no instance profile per lab design
GuardDuty Finding	UnauthorizedAccess:EC2/SSHBruteForce
Security Hub Status	Finding imported and delivered through SecurityHubAlerts email
Remediation / Cleanup	Exposed stack deleted after alert validation
Evidence Limitation	Deletion is documented from the current user update; no cleanup screenshot was provided in this turn.

Architecture and Lifecycle



Project 36 now covers the full lifecycle: intentional exposure, detection, alert delivery, and stack cleanup.

Figure 1 - Controlled public SSH detection lifecycle with cleanup complete.

Implementation and Update Summary

1. Logged into TestAccount1 with administrator access.
2. Created the Exposed CloudFormation stack from the lab template.

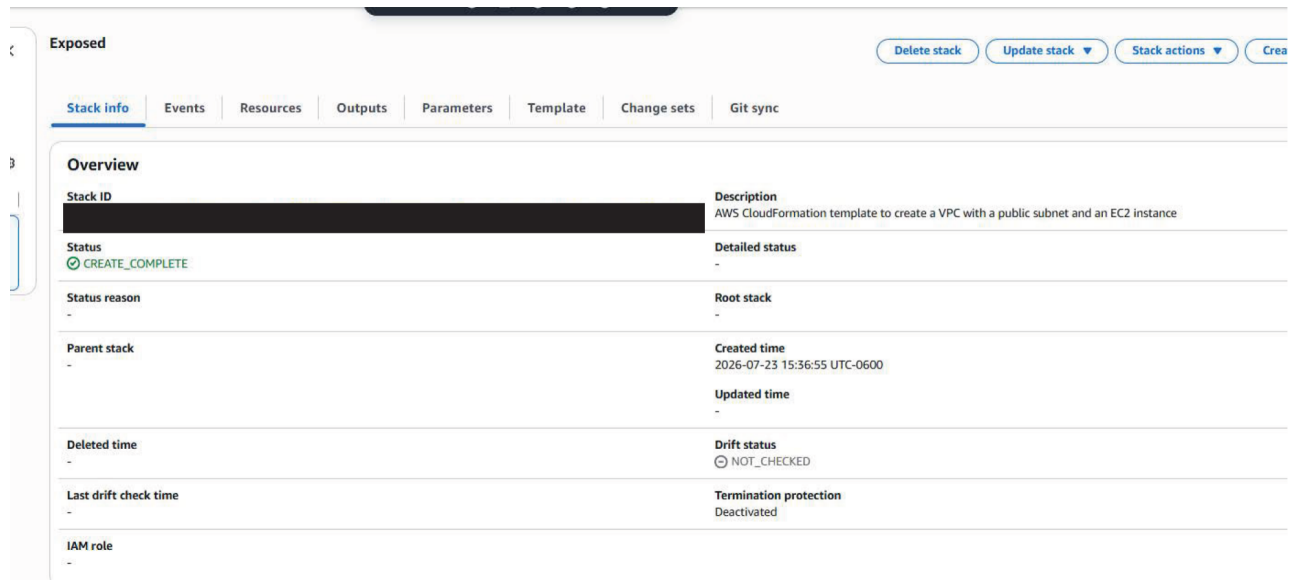
3. Confirmed the stack created the HackMePlease public EC2 instance.
4. Validated that TCP 22 was exposed to 0.0.0.0/0 and outbound Internet traffic was allowed.
5. Maintained the lab safety design by not attaching an EC2 IAM role or instance profile.
6. Waited for real-world SSH scanning or brute-force activity to generate a GuardDuty finding.
7. Received a SecurityHubAlerts email containing an imported Security Hub finding from GuardDuty.
8. Documented the finding type, source IP, destination instance, severity, state, and workflow status.
9. Deleted the Exposed CloudFormation stack after the alert was received and recorded.

Detection Details

Finding type	UnauthorizedAccess:EC2/SSHBruteForce	GuardDuty detected SSH brute-force behavior against the exposed instance.
Finding product	Amazon GuardDuty imported into Security Hub	The Security Hub aggregation path received the GuardDuty result.
Notification path	SecurityHubAlerts SNS email	EventBridge/SNS alert routing delivered the imported finding to email.
Target instance	HackMePlease / EC2 instance	The intentionally exposed detection target received the activity.
Protocol and port	TCP 22 / SSH	The activity matched the lab's deliberate SSH exposure.
Severity	LOW / Normalized 40	The finding was recorded as a low-severity SSH brute-force finding.
Workflow state	NEW; RecordState ACTIVE	The alert arrived as a new active security finding.
Cleanup state	Exposed stack deleted	The intentionally risky resource was removed after validation.

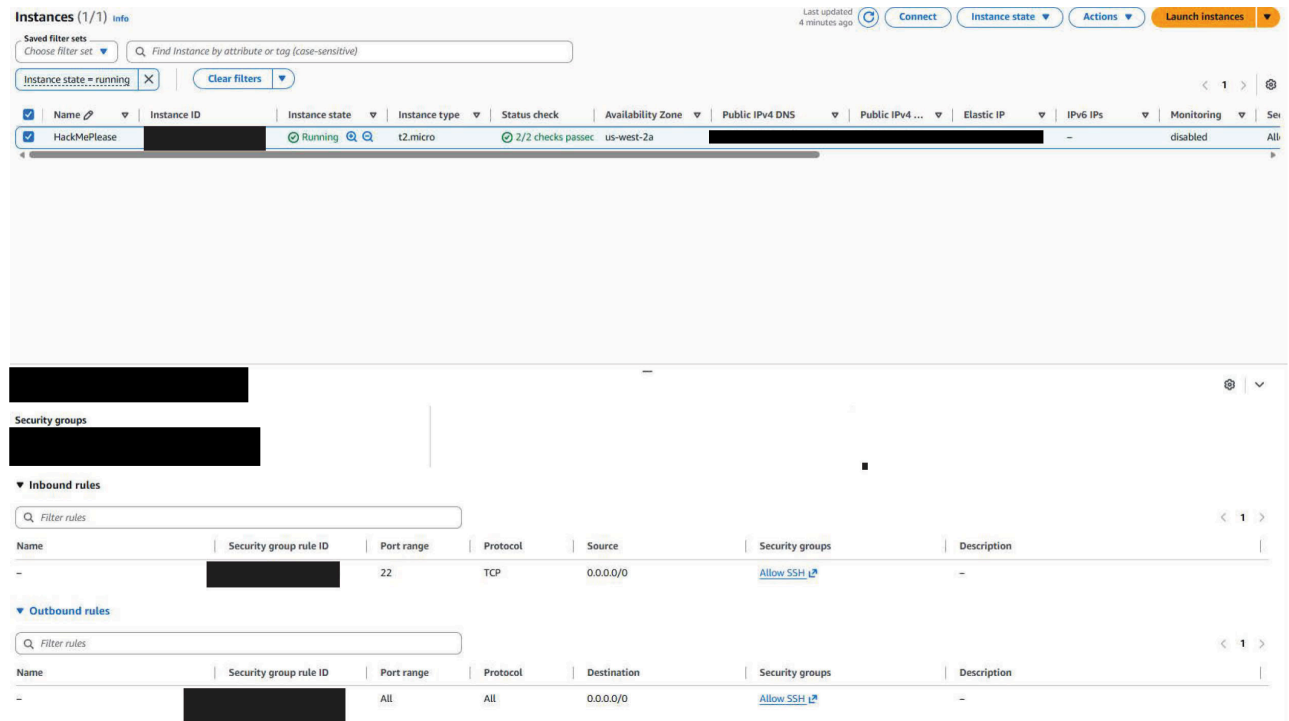
Evidence

Figure 2 - Exposed Stack Created



The CloudFormation evidence shows the Exposed stack created for this lab. Sensitive account and resource identifiers were redacted.

Figure 3 - HackMePlease Public SSH Target



The EC2 evidence shows the HackMePlease instance used as the public SSH exposure target. The lab configuration opened inbound TCP 22 from the Internet and did not attach an IAM role or instance profile. Sensitive values were redacted.

Figure 4 - SecurityHubAlerts Email with GuardDuty SSH Brute-Force Finding



Updated evidence image uses the final redacted alert version with the SNS unsubscribe/footer data redacted.

UnauthorizedAccess:EC2/SSHBruteForce finding. It identifies TCP 22 / SSH, inbound network activity, source IP 203.56.201.183, China/Sichuan Chuanxn IDC, severity LOW / normalized 40, workflow NEW, and the HackMePlease instance tag. Sensitive subscription and account data remain visible in the original email screenshot and should be redacted before public sharing.

CLEANUP EVIDENCE NOTE

Cleanup was completed after the alert was received: the Exposed CloudFormation stack was deleted. No deletion screenshot was supplied, so this is documented as an implementation update rather than screenshot-backed evidence.

Security Analysis

The lab validates the complete detection pipeline: public SSH exposure produced a GuardDuty SSH brute-force finding, Security Hub imported the finding, and the EventBridge/SNS alerting path delivered the notification by email.

The instance had no IAM role or instance profile, which reduces AWS API blast radius if the EC2 host is compromised. It does not stop brute-force attempts; it limits what an attacker can do with AWS credentials from the instance.

Opening SSH to 0.0.0.0/0 is intentionally unsafe and should only be used in a controlled, temporary detection lab. The cleanup step is mandatory because the resource is designed to attract malicious traffic.

The SecurityHubAlerts email screenshot contains sensitive identifiers and an email address. A fully public portfolio version should keep the screenshot redacted or replace it with a sanitized summary.

Deleting the Exposed stack closes the detection loop and moves the project from validation to remediation complete.

Remediation and Cleanup

- Deleted the Exposed CloudFormation stack after confirming the alert.

- Removed the public SSH exposure by deleting the stack-managed EC2 instance and security group resources.
- Preserved the alert evidence in the project documentation before cleanup.
- Next validation option: capture a CloudFormation DELETE_COMPLETE screenshot or CloudTrail DeleteStack event for stronger evidence.

Lessons Learned

Controlled exposure labs can prove whether detective controls work, but they must be time-limited and intentionally cleaned up.

GuardDuty findings can be made more operationally useful when routed into Security Hub and then to EventBridge/SNS notifications.

Security testing should distinguish between exposure, detection, notification, and remediation. This project now covers all four phases.

A finding screenshot is evidence of detection. A deletion screenshot or CloudTrail event would be evidence of remediation.

Production Improvements

- Do not intentionally expose SSH in production environments; use controlled test accounts or isolated sandboxes.
- Use Systems Manager Session Manager instead of public SSH for administration.
- Add EventBridge rules to auto-tag, isolate, or ticket exposed instances after GuardDuty findings.
- Send Security Hub findings to a SIEM or ticketing workflow instead of raw email only.
- Add AWS Config or Security Hub controls to detect security groups allowing SSH from 0.0.0.0/0.
- Use CloudTrail evidence to document DeleteStack and security group deletion events.

Skills Demonstrated

GuardDuty findings	Security Hub import	EventBridge/SNS alert routing
Controlled exposure testing	EC2 public SSH risk	CloudFormation stack cleanup
Evidence handling	Remediation documentation	Portfolio-level security analysis

Resume Bullet

RESUME

Validated an AWS detection pipeline by deploying a controlled public SSH exposure, capturing a GuardDuty UnauthorizedAccess:EC2/SSHBruteForce finding through Security Hub and SNS email, then deleting the exposed CloudFormation stack after detection validation.

STAR Interview Story

Situation: The AWS portfolio already had GuardDuty, Security Hub, EventBridge, and SNS alerting configured, but the detection pipeline needed validation with a real controlled event.

Task: Create a temporary public SSH exposure, capture the resulting alert, and remove the intentionally exposed resource.

Action: I deployed the Exposed stack with HackMePlease, confirmed the SSH exposure pattern, received the SecurityHubAlerts email for a GuardDuty SSH brute-force finding, documented the detection evidence, and deleted the Exposed stack after validation.

Result: The lab proved the detection and notification path worked end-to-end and closed the loop by removing the risky stack after evidence was captured.

Version History

Version	Release Date	Description
v1.0.0	July 26, 2026	Initial documented implementation. Created Exposed stack and HackMePlease public SSH target; project left open while waiting for alerts.
v1.0.1	July 27, 2026	Added SecurityHubAlerts email evidence and confirmed GuardDuty/Security Hub detection for UnauthorizedAccess:EC2/SSHBruteForce.
v1.0.2	July 27, 2026	Documented deletion of the Exposed CloudFormation stack and changed lifecycle state to closed/remediated.
v1.0.3	July 28, 2026	Replaced SecurityHubAlerts evidence image with the final redacted version; SNS unsubscribe/footer data redacted.

References

- Cloud Security Lab a Week (S.L.A.W.) - Let's Get Hacked! Public SSH Edition.
- User-provided Exposed stack evidence screenshot.
- User-provided HackMePlease EC2 evidence screenshot.
- User-provided SecurityHubAlerts email evidence screenshot.
- User-provided cleanup update: Exposed stack deleted.
- Project 22 - Multi-Region GuardDuty Delegated Administration.
- Project 23 - Security Hub Central Configuration.
- Project 24 - EventBridge Security Hub Alerts to SNS Email.